



LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



New Rokarolla Android malware targets 217 banking, crypto apps

Malware Analysis Report

Classification	TLP:CLEAR
Published	2026-06-17
Version	1.0
Author	Lost Boys Cyber
Report Type	Malware Analysis Report

TLP:CLEAR | Lost Boys Cyber | New Rokarolla Android malware targets 217 banking, crypto apps - Malware Analysis Report

Published: 2026-06-17 | TLP:CLEAR | Version: 1.0 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

Table of Contents

1. Executive Summary
2. Sample Metadata
3. Source Review & Confidence
4. Initial Triage and Delivery Assessment
5. Static Analysis
6. Code Analysis
7. Dynamic Analysis
8. Process Tree and Execution Chain
9. Persistence and System Modification
10. Network and Infrastructure Analysis
11. Indicators of Compromise
12. MITRE ATT&CK Mapping
13. Detection Engineering
14. Threat Hunting
15. Triage and Incident Response
16. Validation and Emulation
17. Recommendations
18. References and Refresh Notes

New Rokarolla Android Malware Targets 217 Banking and Cryptocurrency Applications

1. Executive Summary

Rokarolla is a newly reported Android banking trojan documented by Zimperium zLabs and subsequently summarized by BleepingComputer and The Hacker News on 2026-06-16. The campaign is notable because it combines commodity Android banker tradecraft with a broad command surface: Zimperium published 137 supported commands and reported targeting of 217 banking, cryptocurrency, and related applications. The activity should be treated as a mobile malware and fraud-enablement event rather than a conventional enterprise endpoint compromise, but the business impact is material for any organization with mobile banking exposure, BYOD users, crypto treasury operations, executive mobile usage, or customer-facing fraud-risk responsibilities.

The directly reported infection chain begins with malicious websites posing as legitimate application download sources for brands such as TikTok or Google Chrome. A user installs a dropper that masquerades as Google Play Protect, then installs or stages a secondary payload and coerces Accessibility Service, SMS, notification, call-screening, and system-setting privileges. Once privileged, Rokarolla can deploy HTML credential overlays, capture lock-screen PINs/patterns/passwords, log keystrokes and UI content, read and send SMS, intercept notifications, block bank warning calls, rewrite clipboard contents for cryptocurrency theft, disable or steer Google Play Protect, and transmit device telemetry and stolen content over HTTPS C2.

Lost Boys Cyber assesses Rokarolla as high operational risk for Android users and mobile-fraud teams, with medium-to-high confidence in the public technical description. This report is source-backed: no APK was detonated locally during this task, so reverse-engineering and dynamic-analysis claims are attributed to Zimperium's published analysis and corroborating security-media summaries. Defensive priority should be immediate mobile control review, application-installation hardening, Accessibility-permission monitoring, IOC ingestion for published APK hashes and domains, and user education focused on sideloading and unsolicited Accessibility prompts.

Key Finding	Defensive Implication	Priority
Fake-app sideloading is the initial access path.	Enforce managed app stores, block unknown-source installation, and alert on APK installation from browsers or messaging apps.	Critical
Accessibility abuse drives overlays, UI automation, screenshots, keylogging, and permission changes.	Treat unexpected Accessibility grants on Android as a high-severity mobile incident.	Critical
The malware targets 217 banking/crypto apps using downloaded HTML overlays.	Fraud monitoring must include mobile-session anomalies, not just credential-login anomalies.	High
Published IOC set contains 40 APK SHA-256 hashes plus C2/phishing domains.	Ingest hashes/domains into MTD, DNS, proxy, EDR-mobile, and fraud investigation tooling.	High

2. Sample Metadata

Field	Value
Family	Rokarolla
Malware Type	Android banking trojan / mobile remote-control and fraud toolkit

Platform	Android
Primary Sample SHA256	890ecea4ebe4fea692ad36adf02abeb37c181cb7bdb6122cd52d9aaaf e7d6cf3
Additional Hashes	39 additional SHA-256 APK hashes published by Zimperium; see `iocs.csv`
File Type / Format	APK payloads; dropper and secondary-stage flow reported publicly
Delivery Theme	Malicious sites impersonating TikTok, Google Chrome, and Google Play Protect / update flows
First Seen / Reported	Publicly reported 2026-06-16
Analyst Confidence	Medium-high for public-source behavioral claims; low for any unreported sample internals not independently reproduced here
Primary Objective	Credential theft, financial fraud, SMS OTP interception, crypto payment redirection, mobile-device takeover
Report Basis	Zimperium zLabs technical writeup and IOC repository, BleepingComputer intake source, The Hacker News corroboration

This report does not claim local possession of the APK set. Hashes, commands, and behavior are treated as vendor-reported or media-corroborated evidence unless otherwise noted.

3. Source Review & Confidence

Source	Contribution	Confidence
Zimperium zLabs, "Rokarolla: Android Banker with Complete Device Takeover Capabilities"	Primary technical source for infection chain, capabilities, commands, MITRE mapping, C2 examples, and IOC repository links.	High for vendor-observed telemetry and reverse-engineering claims; medium for campaign scope until independently reproduced.
Zimperium IOC GitHub repository, `2026-06-Rokarolla`	Machine-readable APK SHA-256 list and command table used for IOC and detection engineering sections.	High for published indicators and command taxonomy.
BleepingComputer intake article	Original portal intake source; confirms 217 targeted apps, 137 commands, malicious Chrome/TikTok lures, and defensive framing.	Medium-high; derived from Zimperium but useful for independent media validation.
The Hacker News article	Secondary summary confirming overlays, PIN/SMS theft, clipboard redirection, Play Protect disabling, fallback C2 domains, and lack of named attribution.	Medium-high; also derived from Zimperium.
Lost Boys Cyber local validation	Repository QA, report construction, indicator normalization, and detection/hunt drafting. No malware detonation completed.	Medium for analytic synthesis; not a substitute for sample-backed reverse engineering.

Directly observed in sources: the use of an Android dropper, Google Play Protect impersonation, Accessibility abuse, SMS and call-handler privilege requests, HTTPS C2 beaconing, dynamic C2-domain updates, overlay injection for banking/crypto apps, screenshot-based surveillance, and published APK hashes. High-confidence assessment: Rokarolla is designed for fraud

operations that combine credential capture, OTP interception, and post-authentication device manipulation. Lower-confidence or open questions: actor identity, victim geography, distribution volume, APK lineage, and whether all 217 targets were active in the same campaign wave.

4. Initial Triage and Delivery Assessment

Rokarolla's delivery is social-engineering led. Victims are directed to malicious websites that present trojanized or fake versions of popular applications, including TikTok and Google Chrome. Zimperium identified a distribution example at ``hxxps://infocontabilidades.it.com/``. The first-stage application reportedly masquerades as Google Play Protect or a software-update flow and guides the victim into granting privileges needed by the secondary payload.

Variant / Artefact	Delivery Role	Notes
Malicious download site	Initial lure and APK distribution point	Reported site impersonates legitimate app download paths; block at DNS/proxy and mobile web-protection layers.
Dropper APK	Installs or stages core payload	Masquerades as Google Play Protect / update flow to reduce suspicion and obtain user interaction.
Core ROKAROLLA payload	Banking trojan and remote-control component	Requests Accessibility, SMS, notification, call-screening, DND, and system-setting privileges.
HTML injection content	Credential-overlay payload	Fetches dynamically for monitored packages and stored locally for later overlay display.
C2 command set	Remote-control layer	137 published commands include overlay, input, SMS, call, screenshot, clipboard, and Play Protect manipulation actions.

The infection chain is best modeled as a mobile social-engineering compromise followed by privilege escalation through consent abuse. There is no exploited CVE or vendor patch path in the public reporting. The highest-value triage question for a suspected device is therefore not "is Android patched?" but "which untrusted APKs were installed and which high-risk roles/services were granted after installation?"

5.1 File and Build Characteristics

No local APK unpacking was completed for this intake task. Static characteristics below are source-backed observations from Zimperium's analysis and IOC repository.

Static Signal	Evidence	Analyst Value
APK hash cluster	Zimperium published 40 SHA-256 APK hashes in <code>`apks.csv`</code> .	Enables retrospective MTD/EDR-mobile, repository, and file-transfer hunting.
Android banker packaging	Zimperium describes a dropper and secondary payload, both delivered outside trusted app-store channels.	Supports prevention through sideloading restrictions and MDM policy.
Obfuscation / packing	Zimperium maps ROKAROLLA to ATT&CK T1406.002 and notes JSONPacker-style code concealment.	Static detections should avoid relying only on class names or plaintext strings.

Masquerading	Public reporting notes Google Play Protect / Google Play Update impersonation.	Enables visual and package-name review of suspicious "security update" apps.
Command vocabulary	Published command names include `start_keylogger`, `start_vnc`, `request_pin`, `copyclipboard`, `change_sms`, `calls_block`, and `update_config_domen`.	Strong behavioral anchors for reverse-engineering and YARA-like string detection when commands are not fully encrypted.

5.2 Strings, Imports, and Embedded Artefacts

The public command table exposes multiple capability names and operational strings that should guide static triage if APKs are available:

Artefact / String Family	Examples	Interpretation
Overlay commands	`liveoverlay16`, `show_loading_overlay`, `sms_overlay_16`, `call_overlay_16`, `request_pin`, `request_pattern`, `request_password`	Credential and permission deception through full-screen overlays.
Accessibility automation	`tap`, `longclick`, `swipe`, `clicktext`, `clickdesc`, `enter_pattern`, `enter_point`	UI automation and input injection via Accessibility APIs.
Credential / data capture	`start_keylogger`, `startuilogger`, `textextract`, `copyclipboard`, `start_vnc`, `get_contact`	Keystroke logging, UI tree capture, clipboard theft, screenshot surveillance, and contact scraping.
SMS / call control	`send_sms`, `change_sms`, `smsclient`, `callclient`, `disabe_calls`, `calls_block`, `enable_calls`	OTP interception and fraud-alert suppression.
C2 / configuration	`registration_update`, `update_config_domen`, `update_config_injects`, `reset_app_list`, `update_prefix`	Bot enrollment, fallback domains, injected overlay updates, and target-list refreshes.
Evasion / device control	`hide_app`, `disable_sounds_and_vibrations`, `distrub_mode_enabled`, `brightness`, `protectorgoogle_disable`, `open_google_play_protect`	Stealth, user-notification suppression, and security-control manipulation.

5.3 Static Configuration Clues

Zimperium's example C2 update response included fallback HTTPS domains: `beralisvc.info`, `blestorians.cfd`, `abiorime.cfd`, and `morevoms.cfd`. The reported distribution URL is `infocontabilidades.it.com`. Static triage of recovered APKs should search for these domains, hard-coded endpoint paths such as `monitored\_app\_full`, `get\_html\_mapping`, and `save\_apps`, and local storage references for downloaded HTML overlay content. Because C2 can dynamically update active domains, absence of those exact domains in one recovered sample should not be treated as proof of non-infection.

6.1 Reverse-Engineering Method

This report did not perform local decompilation in Ghidra, jadx, apktool, or radare2. Code-analysis findings are derived from Zimperium's published reverse-engineering notes, its command table, and behavior descriptions. The section is included to preserve analyst value and to guide future sample-backed analysis.

6.2 Functions and Logic of Interest

Function / Routine	Evidence	Why It Matters
Dropper-to-payload installation flow	Zimperium describes a dropper that misleads users into installing a secondary payload while impersonating a legitimate security/update app.	Separates initial-access lure from core banker behavior and explains why app-store policy controls matter.
Bot registration	Example JSON contains `botId`, app version, device manufacturer/model, Android version, locale, timezone, screen metrics, battery, RAM, and storage details.	Gives operators inventory and victim-selection context and creates a unique bot identity.
C2 domain update	`update_config_domen` response can deliver multiple HTTPS fallback domains.	Resilience feature; single-domain takedown is insufficient.
Target-list retrieval	`monitored_app_full` returns package names, active/inactive status, and fake login URL paths.	Enables targeted overlay injection only when high-value banking/crypto apps are present.
HTML overlay persistence	`get_html_mapping` / `save_apps` flows transmit installed app lists and store fake HTML content locally.	Allows credential phishing to occur when the legitimate app is opened later.
Lock-screen credential overlay	`request_pin`, `request_pattern`, and `request_password` commands present fake lock-screen surfaces.	Enables control even when the user thinks the phone is locked.
Screenshot pseudo-VNC	`start_vnc` repeatedly captures screenshots as PNGs instead of relying on MediaProjection screen casting.	Avoids obvious screen-recording prompts and supports remote operator awareness.
SMS and call-role abuse	`smsclient`, `callclient`, `send_sms`, `calls_block`, and related commands request default SMS/call roles and then control communications.	Enables OTP theft and suppression of bank fraud calls.
Clipboard manipulation	`copyclipboard` copies victim clipboard data and replaces it with attacker-supplied content.	Supports cryptocurrency payment redirection and data theft.

6.3 Anti-Analysis, Evasion, and Obfuscation

Rokarolla reportedly uses obfuscation/packing and operational evasion rather than a single novel anti-analysis trick. The most important evasion behaviors are user-facing: hiding the app icon, muting audio/vibration, enabling Do Not Disturb, minimizing brightness, suppressing notifications, blocking calls, and using deceptive overlays to keep the victim from noticing background actions. The command vocabulary also includes Play Protect manipulation (`protectorgoogle\_disable`, `open\_google\_play\_protect`, and related reporting of Google Play Protect deactivation), which should be treated as a high-risk sign on any managed Android device.

7.1 Execution Overview

No local sandbox run was performed. Zimperium's dynamic observations show the following execution sequence: installation of a malicious dropper, installation or activation of a secondary payload, repeated permission/role coercion, initial HTTPS beaconing with device telemetry, C2 command exchange, target-list retrieval, local storage of HTML overlays, and runtime overlays when a monitored banking/crypto application is launched.

7.2 Filesystem, Registry, Service, and Task Changes

Android does not use Windows-style registry or scheduled task persistence. Relevant system modifications and artefacts are Android-specific:

Modification / Artefact	Reported Evidence	Investigation Value
Accessibility service grant	Payload requests Accessibility and uses it for UI parsing, click automation, overlays, and screenshots.	Primary host-side triage pivot.
Default SMS handler role	Commands and public reporting describe changing SMS handler status.	Enables SMS read/send and OTP interception.
Call-screening / default call role	Commands include `callclient`, `calls_block`, and call blocking.	Explains blocked bank warning calls and should trigger fraud-response scoping.
Notification access	Commands enable/disable notification listening and clean/cancel notifications.	Enables theft of notification contents and suppression of alerts.
Modify system settings / DND	Commands request WRITE_SETTINGS and DND access.	Supports silent operation and user-interaction suppression.
Local SQLite or app database	Zimperium reports fake HTML overlays stored locally after retrieval.	Device forensics should collect app-private databases before wiping.

7.3 Network and Command-and-Control Behaviour

Rokarolla communicates with C2 over HTTPS. The initial registration payload includes device fingerprint data and is used to assign or update a bot identifier. Subsequent traffic can deliver command instructions, updated C2 domains, target package lists, active/inactive injection status, fake overlay URLs, and exfiltrated SMS/UI/screenshot/clipboard data.

Network Signal	Example / Description	Detection Note
Phishing/distribution URL	`hxtps://infocontablidades.it.com/`	Block and hunt at DNS, proxy, secure web gateway, and mobile browser telemetry.
C2 fallback domains	`beralisvc.info`, `blestorians.cfd`, `abiorime.cfd`, `morevoms.cfd`	Treat as high-confidence Rokarolla-related infrastructure from Zimperium reporting.
Registration payload	Device model, Android version, locale/timezone, screen metrics, battery/RAM/storage, botId.	Look for unusual mobile app HTTPS posts with dense device telemetry soon after sideloaded APK installation.
Overlay retrieval endpoints	`monitored_app_full`, `get_html_mapping`, `save_apps`	Network hunting anchors if URLs are visible through TLS inspection or endpoint telemetry.

7.4 Observed Capability Summary

Capability	Supporting Dynamic Evidence
Banking and crypto credential theft	Targeted package list with active overlay status; HTML fake login pages displayed over real apps.
Lock-screen credential theft	Fake Android lock-screen overlays capture PINs, patterns, and passwords.
SMS OTP theft and sending	SMS read/send commands and default SMS handler role abuse.

Bank fraud-alert suppression	Call-screening role and call-block commands prevent warning calls from ringing or appearing.
Clipboard redirection	Clipboard data can be copied and replaced, supporting wallet-address substitution.
Screenshot surveillance	Snapshot-based screen capture to PNG over C2, avoiding MediaProjection prompts.
UI automation	Accessibility-driven taps, swipes, text entry, and content-description matching.
Defense evasion	App hiding, muting, DND, notification cancellation, brightness changes, and Google Play Protect manipulation.

8. Process Tree and Execution Chain

Android malware execution is better represented as an app/permission state chain than a Windows-style process tree. The following chain summarizes source-backed behavior.

Step	Parent / Trigger	Child / Action	Why It Matters
1	User visits malicious app download site	User sideloads APK posing as TikTok, Chrome, or a security/update component.	Initial access depends on social engineering and unknown-source installation.
2	Dropper activity	Secondary payload is installed or activated while masquerading as Google Play Protect.	Obscures the transition from lure to banker component.
3	First launch / overlay flow	App requests Accessibility, SMS, notification, call, DND, and settings privileges.	Permission grants create the attack surface for device takeover.
4	Payload registration	HTTPS C2 receives device telemetry and issues/updates botId and commands.	Establishes operator control and victim fingerprinting.
5	Target-list retrieval	Malware receives monitored app list and fake HTML overlay URLs.	Allows application-specific banking/crypto credential phishing.
6	Victim opens targeted app	HTML overlay appears above the legitimate app; credentials/card data are captured.	Fraud occurs in the user's trusted mobile-banking context.
7	Operator or automated command use	SMS interception, call blocking, screenshots, clipboard rewriting, keylogging, UI automation.	Converts initial credential theft into transaction approval and device-level fraud support.

9. Persistence and System Modification

Modification Type	Artefact	Evidence	Confidence
Accessibility persistence	Malicious accessibility service remains granted.	Zimperium and media reporting identify Accessibility as the central control path.	High
SMS role modification	App requests default SMS handler and can read/send SMS.	Commands `change_sms`, `change_sms_auto`, `smsclient`, and `send_sms`.	High
Call-screening role modification	App requests call handler/screening capability and can block calls.	Commands `callclient`, `disabe_calls`, `calls_block`, and `enable_calls`.	High
Notification access	Notification listener can be enabled/disabled; notifications can be read or cancelled.	Commands `notification_listen_enabled`, `notification_listen_disable`, and `notification_clian`.	High
System-setting/DND changes	App can request WRITE_SETTINGS, DND, brightness, vibration/audio changes.	Published command table and Zimperium evasion discussion.	Medium-high
App concealment	App icon hiding and deceptive update screens.	Zimperium notes app hiding and update/install overlays.	Medium-high
Local overlay storage	Fake HTML pages stored locally after C2 retrieval.	Zimperium reports local SQLite/database storage for overlay content.	Medium

Persistence is anchored in user-granted Android permissions and roles. Remediation must remove the malicious app, revoke high-risk grants, review installed APK provenance, rotate credentials used on the device, and validate that SMS/call/default-app settings were restored.

10. Network and Infrastructure Analysis

IOC / Infrastructure	Type	Role	Stability / Confidence
`infocontablidades.it.com`	Domain / URL	Reported malicious distribution site for fake app downloads.	Medium-high; may be ephemeral but useful for historical DNS/proxy review.
`beralisvc.info`	Domain	C2 fallback domain in Zimperium example.	High as source-reported IOC; operational availability may change.
`blestorians.cfd`	Domain	C2 fallback domain in Zimperium example.	High as source-reported IOC; operational availability may change.
`abiorime.cfd`	Domain	C2 fallback domain in Zimperium example.	High as source-reported IOC; operational availability may change.
`morevoms.cfd`	Domain	C2 fallback domain in	High as source-reported IOC;

		Zimperium example.	operational availability may change.
Zimperium APK SHA-256 set	File hashes	Known Rokarolla APK samples.	High for matching known files; low for future repacks.

Rokarolla's fallback-domain design means infrastructure indicators should be used for scoping and immediate blocking but not as the sole detection strategy. A mature detection approach should combine IOC matching with behavioral signals: recent sideloading, Accessibility grant changes, unexpected default-SMS/default-call role changes, notification-listener grants, high-risk overlay behavior, and unusual HTTPS traffic by newly installed apps.

11. Indicators of Compromise

Machine-readable indicators are preserved in `iocs.csv`. The list intentionally distinguishes between source-reported hashes and source-reported domains; no local malware detonation generated additional network or host indicators during this task.

IOC Type	Example / Count	Source	Operational Notes
SHA-256 APK hash	40 hashes; example `890ecea4ebe4fea692ad36adf02abeb37c181cb7bdb6122cd52d9aaafe7d6cf3`	Zimperium IOC repository	Ingest into MTD, EDR-mobile, file scanning, and download telemetry; expect repacking.
Distribution domain	`infocontablidades.it.com`	Zimperium technical writeup	Block and hunt for historical visits/downloads.
C2 domains	`beralisvc.info`, `blestorians.cfd`, `abiorime.cfd`, `morevoms.cfd`	Zimperium C2 example	Block and hunt; treat hits as high-priority mobile incident leads.
Command strings	137 published command names	Zimperium commands repository	Useful for APK static triage, YARA conditions, and reverse-engineering pivots.
Android role/permission artefacts	Accessibility, notification listener, default SMS, call screening, DND, WRITE_SETTINGS	Zimperium behavior report	Host telemetry and MDM controls should flag unexpected grants to sideloaded apps.

12. MITRE ATT&CK Mapping

Technique	Name	Evidence
T1660	Phishing	Malicious websites lure users into installing fake TikTok/Chrome/security-update APKs.
T1624.001	Event Triggered Execution: Broadcast Receivers	Zimperium maps SMS-event receiver behavior for event-triggered execution.
T1655.001	Masquerading: Match Legitimate Name or Location	Dropper/payload impersonates Google Play Protect / Google Play Update.
T1516	Input Injection	Accessibility-driven taps, swipes, text injection, pattern input, and overlay interaction.
T1406.002	Obfuscated Files or Information: Software	Zimperium reports JSONPacker-style

	Packing	concealment.
T1414	Clipboard Data	`copyclipboard` can copy and replace clipboard contents, including crypto wallet strings.
T1417.001	Input Capture: Keylogging	`start_keylogger` captures victim keystrokes.
T1417.002	Input Capture: GUI Input Capture	UI logger and Accessibility tree capture expose screen content.
T1517	Access Notifications	Notification-listener commands read or suppress notification content.
T1418	Software Discovery	Installed application/package list is transmitted to support target matching.
T1426	System Information Discovery	Registration payload collects device manufacturer, model, Android version, locale, screen, battery, RAM, and storage.
T1513	Screen Capture	Snapshot-based pseudo-VNC captures PNG screenshots.
T1429	Audio Capture	Zimperium maps audio capture; commands also mute audio to hide fraud activity.
T1616	Call Control	Call-screening role and call-block commands suppress incoming bank calls.
T1636.004	Protected User Data: SMS Messages	Reads and sends SMS, enabling OTP interception.
T1637	Dynamic Resolution	C2 can update fallback domains and injection endpoints dynamically.
T1646	Exfiltration Over C2 Channel	Device telemetry, UI data, SMS, screenshots, and credentials are sent over C2.
T1582	SMS Control	Public mapping notes SMS read/send capability and role abuse.

13.1 Detection Logic Summary

Signal	Telemetry Source	Analytic Goal	Tuning Notes
Known Rokarolla APK hash observed on device or in download telemetry.	MTD/EDR-mobile, MDM app inventory, proxy downloads, file gateway.	Identify known samples quickly.	Hash detections are high-confidence but incomplete against repacks.
Recently sideloaded APK requests Accessibility plus SMS/call/notification roles.	MDM, Android Enterprise audit, MTD behavioral telemetry.	Catch the core privilege pattern before fraud completes.	Some legitimate accessibility apps need allowlisting; combine with unknown-source installation.
New app becomes default SMS or call-screening handler.	MDM, Android logs, MTD.	Detect OTP interception and bank-call suppression path.	Tune to approved messaging/dialer apps by

			package and publisher.
Unexpected Accessibility-driven overlay or screen-capture behavior by a non-enterprise app.	MTD, app-vetting runtime protection, EDR-mobile.	Surface credential-overlay and pseudo-VNC behavior.	Requires mobile security telemetry; SIEM-only environments may lack visibility.
DNS/HTTPS contact to published domains.	DNS logs, secure web gateway, mobile VPN/proxy, MTD web protection.	Identify infected devices or lure exposure.	Domains are likely ephemeral; retain as scoping signals.

13.2 Detection Content

<pre> rule Android_Rokarolla_Command_Strings_SourceReported { meta: description = "Detects source-reported Rokarolla Android banker command strings in unpacked APK content" author = "Lost Boys Cyber" date = "2026-06-16" tlp = "TLP:CLEAR" confidence = "medium" source = "Zimperium 2026-06 Rokarolla command repository" strings: \$cmd1 = "update_config_domen" ascii \$cmd2 = "start_keylogger" ascii \$cmd3 = "copyclipboard" ascii \$cmd4 = "request_pin" ascii \$cmd5 = "request_pattern" ascii \$cmd6 = "request_password" ascii \$cmd7 = "start_vnc" ascii \$cmd8 = "calls_block" ascii \$cmd9 = "protectorgoogle_disable" ascii \$cmd10 = "sms_overlay_16" ascii \$cmd11 = "call_overlay_16" ascii \$cmd12 = "monitored_app_full" ascii condition: 5 of (\$cmd*) } </pre>	<pre> title: Android Device Granted High-Risk Roles After Sideloaded APK Installation id: 1f31c28d-5574-4b4e-a2a5-rokarolla-mobile-roles status: experimental description: Detects a mobile telemetry pattern consistent with Rokarolla-style Android banker privilege acquisition. author: Lost Boys Cyber date: 2026/06/16 references: - https://zimperium.com/blog/rokarolla-android-banker-with-complete-device-takeover-capabilities logsource: product: android category: mobile_mdm detection: sideload: install_source contains: - browser - package_installer - unknown high_risk_role: event.action contains: - accessibility_service_enabled - default_sms_app_changed - call_screening_role_granted - notification_listener_enabled - write_settings_granted </pre>
--	---

```

timeframe: 1h
condition: sideload and high_risk_role
falsepositives:
- Approved accessibility tools installed through managed channels
- Enterprise SMS/call-management applications with documented package names
level: high

// Microsoft Sentinel / MDE-style mobile hunt: suspicious Android privilege cluster after APK
sideloading.
// Field names vary by MDM/MTD connector; adapt DeviceEvents AdditionalFields mappings to the deployed
schema.
let Lookback = 14d;
let RiskyActions = dynamic([
  "accessibility_service_enabled",
  "default_sms_app_changed",
  "call_screening_role_granted",
  "notification_listener_enabled",
  "write_settings_granted",
  "do_not_disturb_access_granted"
]);
DeviceEvents
| where Timestamp > ago(Lookback)
| where OSPlatform =~ "Android" or DeviceType has "Mobile"
| extend Action = tostring(ActionType), PackageName = tostring(AdditionalFields.PackageName),
InstallSource = tostring(AdditionalFields.InstallSource)
| summarize Actions = make_set(Action), Packages = make_set(PackageName), Sources =
make_set(InstallSource), FirstSeen=min(Timestamp), LastSeen=max(Timestamp) by DeviceId, DeviceName
| where set_has_element(Actions, "apk_installed") or tostring(Sources) has_any ("unknown", "browser",
"package_installer")
| where array_length(set_intersect(Actions, RiskyActions)) >= 2
| project FirstSeen, LastSeen, DeviceName, DeviceId, Actions, Packages, Sources

index=mobile sourcetype IN (android:mdm,android:mtd,android:events)
| eval action=coalesce(action, event_action, action_type), package=coalesce(package_name, app_package),
source=coalesce(install_source, installer)
| stats values(action) as actions values(package) as packages values(source) as sources min(_time) as
firstSeen max(_time) as lastSeen by device_id device_name
| search (actions="*apk_installed*" OR sources IN ("*unknown*", "*browser*", "*package_installer*"))
| eval risky=mvcount(mvfilter(match(actions, "accessibility_service_enabled|default_sms_app_changed|
call_screening_role_granted|notification_listener_enabled|write_settings_granted|
do_not_disturb_access_granted")))
| where risky>=2
| convert ctime(firstSeen) ctime(lastSeen)

```

13.3 Detection Validation and Blind Spots

The YARA rule is designed for unpacked APK/static triage and relies on command strings from Zimperium's public command list. It may miss encrypted or repacked variants and should be paired with APK hash matching and behavioral MTD telemetry. The Sigma/KQL/SPL analytics are schema patterns rather than drop-in rules for every Android telemetry stack; field mapping must be validated against the organization's MDM/MTD connector. The highest-confidence operational detections combine a sideloaded app with unexpected Accessibility, SMS, call-screening, notification-listener, and system-setting grants.

14.1 Hunt Hypotheses

- A device exposed to Rokarolla or a similar Android banker will show a recent sideloaded APK followed by Accessibility and at least one communications role change.
- A compromised device may contact known Rokarolla infrastructure or a newly registered lookalike domain shortly after installation.
- Fraud-support behavior will involve SMS/notification access, call blocking, or clipboard modifications near mobile-banking or crypto-wallet activity.
- Even without IOC hits, devices with fake "Play Protect", "Chrome", or "TikTok" packages installed from unknown sources deserve manual review.

14.2 Hunt Queries

```
// Hunt 1: Known Rokarolla APK hashes in download, file, or mobile inventory telemetry.
```

```

let RokarollaSha256 = dynamic([
"890ecea4ebe4fea692ad36adf02abeb37c181cb7bdb6122cd52d9aaafe7d6cf3",
"7aa389f25997610a96f014977eecd6d69142bdc63841e0d84976e3e621831303",
"4e2cbefc6bdbfdb6e885057ce47d460e3d3355a5e97db51b22e9c5a14e14302b",
"1ba364113c4cec5542d1b2c76d7c163a66bdf90bc373256d5178f880f9742960"
]);
DeviceFileEvents
| where Timestamp > ago(30d)
| where SHA256 in~ (RokarollaSha256)
| project Timestamp, DeviceName, DeviceId, FileName, FolderPath, SHA256, InitiatingProcessFileName,
InitiatingProcessCommandLine

// Hunt 2: Mobile devices contacting source-reported Rokarolla infrastructure.
let RokarollaDomains = dynamic(["infocontablidades.it.com", "beralisvc.info", "blestorians.cfd",
"abiorime.cfd", "morevoms.cfd"]);
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemoteUrl has_any (RokarollaDomains) or AdditionalFields has_any (RokarollaDomains)
| project Timestamp, DeviceName, DeviceId, InitiatingProcessFileName, InitiatingProcessCommandLine,
RemoteUrl, RemoteIP, RemotePort, Protocol

// Hunt 3: Suspicious Android role and Accessibility changes clustered on one device.
let RiskyActions = dynamic(["accessibility_service_enabled", "default_sms_app_changed",
"call_screening_role_granted", "notification_listener_enabled", "write_settings_granted",
"do_not_disturb_access_granted"]);
DeviceEvents
| where Timestamp > ago(30d)
| where OSPlatform =~ "Android" or DeviceType has "Mobile"
| where ActionType in~ (RiskyActions) or toString(AdditionalFields) has_any (RiskyActions)
| extend PackageName = toString(AdditionalFields.PackageName)
| summarize FirstSeen=min(Timestamp), LastSeen=max(Timestamp), Actions=make_set(ActionType),
Packages=make_set(PackageName), EventCount=count() by DeviceId, DeviceName
| where array_length(Actions) >= 2 or EventCount >= 3
| order by LastSeen desc

index=proxy OR index=dns OR index=mobile earliest=-30d
( infocontablidades.it.com OR beralisvc.info OR blestorians.cfd OR abiorime.cfd OR morevoms.cfd )
| eval domain=coalesce(query, url_domain, dest_host, host)
| stats count min(_time) as firstSeen max(_time) as lastSeen values(src_ip) as src_ip values(user) as
user values(app) as app by device_id device_name domain
| convert ctime(firstSeen) ctime(lastSeen)
| sort - lastSeen

```

14.3 Triage Guidance for Hunt Hits

A hash hit should be treated as a confirmed exposure to a known Rokarolla sample unless a controlled malware-analysis lab account is expected. A domain hit is a high-priority lead but should be validated for DNS sinkhole, security-research, or sandbox context before customer notification. A behavior-only hit requires mobile-device review: inspect app inventory, installer source, Accessibility services, default SMS/call apps, notification listeners, DND/WRITE_SETTINGS grants, and recent banking/crypto account activity. Escalate to incident response when high-risk grants are paired with unknown-source installation or known infrastructure contact.

15. Triage and Incident Response

Phase	Action	Rationale
Containment	Remove the device from trusted mobile access, suspend mobile banking/crypto actions, and block known domains/hashes.	Prevents continued OTP theft, overlay capture, and transaction manipulation.
Evidence preservation	Capture MDM/MTD timeline, installed apps, package names, install sources, permission/role grants, DNS/proxy history, SMS/call-handler state, and screenshots of suspicious apps before wiping.	Mobile wipes destroy useful fraud-scoping evidence.

Credential response	Reset credentials used on the device, revoke sessions, rotate MFA methods that relied on SMS, and review recent mobile banking/crypto transactions.	Rokarolla targets credentials, SMS OTPs, clipboard values, and active sessions.
Device remediation	Uninstall malicious apps, revoke Accessibility/notification/SMS/call/DND/ WRITE_SETTINGS grants, restore Play Protect, then rebuild or factory reset if compromise is confirmed.	Permission rollback alone may not remove all local artefacts or secondary payloads.
Fraud scoping	Coordinate with banking/fraud teams to search for blocked calls, unusual transaction attempts, new payees, wallet-address changes, and SMS OTP usage.	Malware's objective is financial theft, not merely persistence.
Enterprise hardening	Enforce managed app stores, disallow unknown-source installation, deploy MTD, and alert on risky Android roles.	Reduces recurrence across BYOD and managed fleets.

Do not treat this as a patch-only issue. The decisive controls are mobile application provenance, permission governance, fraud monitoring, and endpoint/mobile security telemetry.

16. Validation and Emulation

Validation completed for this report:

Validation Item	Result
Primary source reviewed	Zimperium zLabs article and IOC repository reviewed.
Secondary source reviewed	BleepingComputer intake source and The Hacker News corroboration reviewed.
IOC normalization	Published domains and 40 APK SHA-256 hashes normalized into `iocs.csv`.
Detection drafting	YARA, Sigma, KQL, and SPL content drafted from source-reported behavior and command names.
Local malware execution	Not performed. No claim is made that Lost Boys Cyber detonated or decompiled the APKs for this intake task.

Safe emulation options for defenders include creating benign Android test events for Accessibility grant changes, default SMS/call-handler changes, and synthetic DNS lookups to a blocked test domain. Do not interact with live Rokarolla domains or execute suspicious APKs outside a controlled mobile malware lab. If sample-backed analysis is later required, use an isolated Android emulator or sacrificial device with packet capture, DNS sinkholing, apktool/jadx/Ghidra review, and explicit evidence preservation under the report's `evidence/` directory.

17. Recommendations

Priority	Owner	Action	Rationale
Critical	Mobile Security / MDM	Block unknown-source APK installation and enforce managed app-store installation for corporate and executive devices.	Rokarolla's initial access depends on sideloading.

Critical	Mobile Security / SOC	Alert on new Accessibility grants by unapproved apps, especially when paired with SMS, call, notification, DND, or WRITE_SETTINGS privileges.	Accessibility abuse is the enabling control for overlays, screenshots, and UI automation.
High	SOC / Threat Intel	Ingest the 40 SHA-256 hashes and five source-reported domains into MTD, DNS, proxy, SIEM, and case-management watchlists.	Supports immediate scoping of known Rokarolla exposure.
High	Fraud / Identity	Replace SMS-based MFA for high-risk users and monitor mobile-banking sessions for device-change, payee-change, and transaction-confirmation anomalies.	Rokarolla steals SMS OTPs and can suppress bank calls.
High	User Awareness	Warn users that Google Play Protect does not require installing APKs from websites and that unexpected Accessibility prompts are a red flag.	Addresses the social-engineering path directly.
Medium	Detection Engineering	Implement behavior analytics for sideloaded app plus Accessibility/default SMS/call-screening role cluster.	Behavioral detection survives hash and domain churn.
Medium	Incident Response	Add Android-specific collection steps to mobile fraud playbooks.	Preserves evidence before factory reset and supports faster bank/fraud coordination.
Medium	AppSec / Mobile App Owners	Consider runtime app protection against overlay attacks, screen capture, and Accessibility abuse for sensitive customer-facing apps.	Reduces credential-overlay success against protected banking/crypto applications.

18. References and Refresh Notes

- [1] Zimperium zLabs, "Rokarolla: Android Banker with Complete Device Takeover Capabilities," published 2026-06-16, <https://zimperium.com/blog/rokarolla-android-banker-with-complete-device-takeover-capabilities>
- [2] Zimperium IOC repository, `2026-06-Rokarolla/commands.md`, <https://github.com/Zimperium/IOC/tree/master/2026-06-Rokarolla/commands.md>
- [3] Zimperium IOC repository, `2026-06-Rokarolla/apks.csv`, <https://github.com/Zimperium/IOC/tree/master/2026-06-Rokarolla/apks.csv>
- [4] BleepingComputer, "New Rokarolla Android malware targets 217 banking, crypto apps," published 2026-06-16, <https://www.bleepingcomputer.com/news/security/new-rokarolla-android-malware-targets-217-banking-crypto-apps/>
- [5] The Hacker News, "New Rokarolla Android Malware Steals PINs, SMS Codes, and Crypto Wallet Funds," published 2026-06-16, <https://thehackernews.com/2026/06/new-rokarolla-android-malware-steals.html>

Refresh notes: re-check the Zimperium IOC repository before final publication or operational blocking because domains and APK hashes can age quickly. If a real sample is later provided, rerun the malware-analysis workflow with

apktool/jadx/Ghidra, capture network traffic through a sinkholed lab, and replace source-backed code/dynamic sections with observed evidence.